VulnSight AI Security Assessment Report

Scan 2173bbdc-67be-451e-84ba-6b67a0a7d659 · Standard · Completed

Target: Synthetic vulnerable fixture (http://fixture.example.test/)

Authorized hostnames: fixture.example.test · Ports: 80

Started: 2026-10-22T08:51:38.428459 · Completed: 2026-10-22T08:51:38.939813 · Duration: 0.511354 seconds

Executive summary

The standard assessment recorded 12 evidence-backed finding(s) across 8 of 8 checks. Results are limited to the bounded checks listed below and do not establish complete security.

Severity distribution

Critical	High	Medium	Low	Informational
0	0	1	10	1

Completed checks

target_scope — Target owner, authorization state, exact hostname allowlist and public DNS answers were validated. (2026-10-22T08:51:38.448023)

tls — TLS handshake result recorded; one handshake does not represent every protocol/cipher configuration. (2026-10-22T08:51:38.893333)

http_connectivity — Received HTTP 200 response; response body and cookie values are not persisted. (2026-10-22T08:51:38.898525)

https_redirect — HTTP-to-HTTPS behavior observed; unsafe/out-of-scope redirects were not followed. (2026-10-22T08:51:38.904303)

security_headers — Security response header policy assessed from the observed HTTP response. (2026-10-22T08:51:38.918663)

cookies — Cookie flag metadata assessed; cookie values were not added to findings. (2026-10-22T08:51:38.927397)

safe_input_reflection — A bounded non-executable GET marker probe completed; the marker itself was not persisted. (2026-10-22T08:51:38.933723)

response_configuration — Response implementation-identification headers were assessed. (2026-10-22T08:51:38.938509)

Findings and remediation

1. HTTPS endpoint could not be established — Low (tls)

URL: https://fixture.example.test/ · Status: open · Confidence: low · Verification: observed

A TLS handshake to the authorized hostname on port 443 did not complete. This observation does not distinguish an intentionally HTTP-only service from an unavailable TLS endpoint.

Impact: Users may lack a protected transport path if this service handles sensitive data.

Evidence: {"hostname": "fixture.example.test", "port": 443, "reachable": false, "certificate_trusted": null, "hostname_matches": null, "valid_from": null, "valid_until": null, "is_expired": null, "is_not_yet_valid": null, "negotiated_version": null, "cipher": null, "error_class": "tls_unavailable", "limitation": "A single handshake does not test every supported TLS version, cipher or certificate path."}

Remediation: If HTTPS is intended, configure a reachable TLS listener with a valid certificate and redirect HTTP to HTTPS.

References: https://www.rfc-editor.org/rfc/rfc8446

2. HTTP endpoint did not redirect to HTTPS — Medium (transport)

URL: http://fixture.example.test/ · Status: open · Confidence: medium · Verification: observed

The observed HTTP redirect did not provide a verifiable in-scope HTTPS upgrade, or an HTTPS request attempted to downgrade. The scanner did not follow an unsafe or out-of-scope destination.

Impact: A user-agent may remain on an unencrypted connection or be directed outside the explicitly authorized hostname scope.

Evidence: {"source_url": "http://fixture.example.test/", "redirect_destination": null, "decision": "no_https_redirect"}

Remediation: Serve a valid HTTPS endpoint and direct HTTP requests to its HTTPS equivalent; keep redirects within the authorized hostname scope.

References: https://datatracker.ietf.org/doc/html/rfc6797

3. Missing Content-Security-Policy header — Low (security_headers)

URL: http://fixture.example.test/ · Status: open · Confidence: low · Verification: observed

The response does not advertise a Content-Security-Policy; whether one is appropriate depends on the application.

Impact: Security behavior may be weaker than the recommended baseline; actual exploitability depends on the application context.

Evidence: {"expected_setting": "A deliberate Content-Security-Policy appropriate to the application", "observed_name": "Content-Security-Policy", "present_policy": false}

Remediation: Define and deploy a restrictive Content-Security-Policy after testing the application's required resources.

References: https://owasp.org/www-project-secure-headers/

4. Missing X-Content-Type-Options header — Low (security_headers)

URL: http://fixture.example.test/ · Status: open · Confidence: low · Verification: observed

The response does not explicitly opt out of MIME-type sniffing.

Impact: Security behavior may be weaker than the recommended baseline; actual exploitability depends on the application context.

Evidence: {"expected_setting": "X-Content-Type-Options: nosniff", "observed_name": "X-Content-Type-Options", "present_policy": false}

Remediation: Send X-Content-Type-Options: nosniff for applicable responses.

References: https://owasp.org/www-project-secure-headers/

5. Missing Referrer-Policy header — Low (security_headers)

URL: http://fixture.example.test/ · Status: open · Confidence: low · Verification: observed

The response does not state how much referrer information may be sent to other origins.

Impact: Security behavior may be weaker than the recommended baseline; actual exploitability depends on the application context.

Evidence: {"expected_setting": "A deliberate Referrer-Policy such as strict-origin-when-cross-origin", "observed_name": "Referrer-Policy", "present_policy": false}

Remediation: Set a Referrer-Policy appropriate to the application's privacy and navigation requirements.

References: https://owasp.org/www-project-secure-headers/

6. Missing Permissions-Policy header — Low (security_headers)

URL: http://fixture.example.test/ · Status: open · Confidence: low · Verification: observed

The response does not explicitly restrict browser features that the application does not need.

Impact: Security behavior may be weaker than the recommended baseline; actual exploitability depends on the application context.

Evidence: {"expected_setting": "A deliberate Permissions-Policy appropriate to the features used", "observed_name": "Permissions-Policy", "present_policy": false}

Remediation: Define a least-privilege Permissions-Policy for browser features used by the application.

References: https://owasp.org/www-project-secure-headers/

7. Missing effective framing protection — Low (security_headers)

URL: http://fixture.example.test/ · Status: open · Confidence: low · Verification: observed

Neither CSP frame-ancestors nor an effective X-Frame-Options directive was observed.

Impact: Security behavior may be weaker than the recommended baseline; actual exploitability depends on the application context.

Evidence: {"expected_setting": "CSP frame-ancestors or X-Frame-Options: DENY/SAMEORIGIN", "observed_name": "Content-Security-Policy / X-Frame-Options", "present_policy": false}

Remediation: Set CSP frame-ancestors or X-Frame-Options to a deliberate framing policy.

References: https://owasp.org/www-project-secure-headers/

8. Cookie is missing Secure — Low (cookies)

URL: http://fixture.example.test/ · Status: open · Confidence: low · Verification: observed

The cookie is set without the Secure attribute; review this in the context of the cookie's role and transport requirements.

Impact: This cookie attribute is a contextual defense-in-depth control; the cookie's role and application behavior determine practical impact.

Evidence: {"cookie_name": "session", "expected_setting": "Secure for cookies that should only travel over HTTPS", "observed_attributes": []}

Remediation: Set Secure where the cookie is intended for HTTPS-only transport.

References: https://owasp.org/www-community/controls/SecureCookieAttribute; https://cheatsheetseries.owasp.org/cheatsheets/Session_Management_Cheat_Sheet.html

9. Cookie is missing HttpOnly — Low (cookies)

URL: http://fixture.example.test/ · Status: open · Confidence: low · Verification: observed

The cookie is set without HttpOnly; review whether client-side scripts need to read it.

Impact: This cookie attribute is a contextual defense-in-depth control; the cookie's role and application behavior determine practical impact.

Evidence: {"cookie_name": "session", "expected_setting": "HttpOnly unless client-side script access is deliberately required", "observed_attributes": []}

Remediation: Set HttpOnly for cookies that do not need to be read by client-side scripts.

References: https://owasp.org/www-community/controls/SecureCookieAttribute; https://cheatsheetseries.owasp.org/cheatsheets/Session_Management_Cheat_Sheet.html

10. Cookie is missing SameSite — Low (cookies)

URL: http://fixture.example.test/ · Status: open · Confidence: low · Verification: observed

The cookie is set without SameSite; the appropriate setting depends on the application's cross-site flow.

Impact: This cookie attribute is a contextual defense-in-depth control; the cookie's role and application behavior determine practical impact.

Evidence: {"cookie_name": "session", "expected_setting": "A deliberate SameSite value, commonly Lax or Strict", "observed_attributes": []}

Remediation: Set SameSite deliberately based on the application's cross-site navigation and embedding requirements.

References: https://owasp.org/www-community/controls/SecureCookieAttribute; https://cheatsheetseries.owasp.org/cheatsheets/Session_Management_Cheat_Sheet.html

11. Benign query marker appears in response body — Low (input_validation)

URL: http://fixture.example.test/ · Status: open · Confidence: medium · Verification: suspected

A unique, non-executable GET query marker was observed in the response body. Reflection alone does not establish HTML execution, script injection, or exploitability.

Impact: If untrusted data is later inserted into an active HTML/script context without contextual output encoding, cross-site scripting may be possible; this check does not test that condition.

Evidence: {"probe_method": "GET", "probe_parameter": "vulnsight_probe", "marker_reflected": true, "body_truncated": false, "response_status": 200}

Remediation: Contextually encode untrusted data before rendering and apply an appropriate output-encoding policy. Validate the result with a separate authorized manual review.

References: https://owasp.org/www-community/attacks/xss/

12. Response discloses server implementation details — Informational (response_configuration)

URL: http://fixture.example.test/ · Status: open · Confidence: low · Verification: observed

The response includes one or more server-identification headers. This is an informational observation, not proof that the advertised component is vulnerable.

Impact: Detailed version disclosure may assist reconnaissance when combined with other information.

Evidence: {"observed_headers": {"server": "SyntheticFixture/0.1"}}

Remediation: Remove unnecessary product/version headers where practical; do not treat concealment as a substitute for patching.

References: https://owasp.org/www-project-secure-headers/

Limitations and disclaimer

- Only bounded passive and benign GET checks were used; no active exploit, credential attack, data extraction or denial-of-service check was performed.

- A single TLS handshake and sampled HTTP response do not establish every protocol, endpoint, authentication state or application security property.

- OWASP ZAP is not configured; no ZAP or OWASP Top 10 coverage is claimed.

This report describes observations from a limited, authorized assessment at the recorded time. It is not a guarantee that the application is secure, does not replace a full security review, and should be interpreted by qualified personnel in context.